Network Security - Lab Project

Teaching Assistant: Navid Ladner
navid.ladner@ulb.be

March 2026

1 Motivation

Enterprises and industrial control systems, as illustrated with Figure 1, have specific network security requirements in order to avoid potentially devastating consequences whenever a node in their network is compromised. In such system, for security reasons, a demilitarized zone (DMZ) is used between the Internet (untrusted zone) and the enterprise network (trusted zone); the private enterprise network is not reachable from the Internet except for the traffic passing through a VPN gateway and the enterprise application servers are made available to the Internet using a reverse proxy. The intranet may also be segmented, for instance, to avoid potentially compromised application servers to interact with the office network or more sensitive nodes from the enterprise.

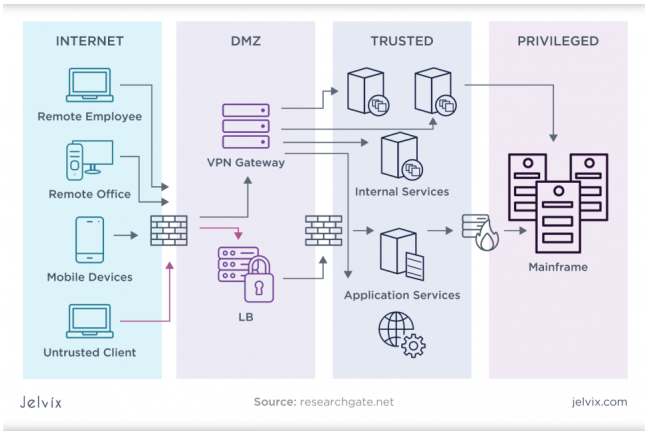

Figure 1: Illustration of enterprise security architecture.

2 Project Description

For this project, you will have to deploy on GNS3 a small enterprise network infrastructure as depicted on Figure 2. This topology only represent the basis of the project. The components present are described below. Through the different milestones, you will be ask to implement other elements and configure them accordingly. The assumptions made through the different milestones are to be kept for the following ones, unless explicitly specified.

The topology illustrated in Figure 2 is divided in 2 main parts: the external users and the company or *enterprise*.

The external users are composed of the *Remote Employee* which tries to access the office network PCs and make request to the reverse proxy. The *Malicious* PC is the adversary that tries to access the office network and/or the web servers behind the firewall or the reverse proxy.

The company network is divided in 4 parts: the office network, the server network, the firewall and the reverse proxy. The office network contains the 2 PCs to which a user can either connect locally or remotely. The servers are simple webservers used by only the IT departement (PC-1) and can be accessed through the firewall or by the reverse proxy.

All parts are connected via routers. The connection between the external users and the office network is made through a VPN. The office network and the server network are separated with a firewall that filters out the traffic. Finally, the external users can access the server network via a reverse proxy connected between R1 and R3.

2.1 Evaluation

The project will be divided into three parts, each of them being evaluated on a dedicated milestone. For each milestone, groups should present their work for **10 minutes** with **prepared test cases** to illustrate the functioning of their topology during the demo (i.e. using pings and Wireshark).

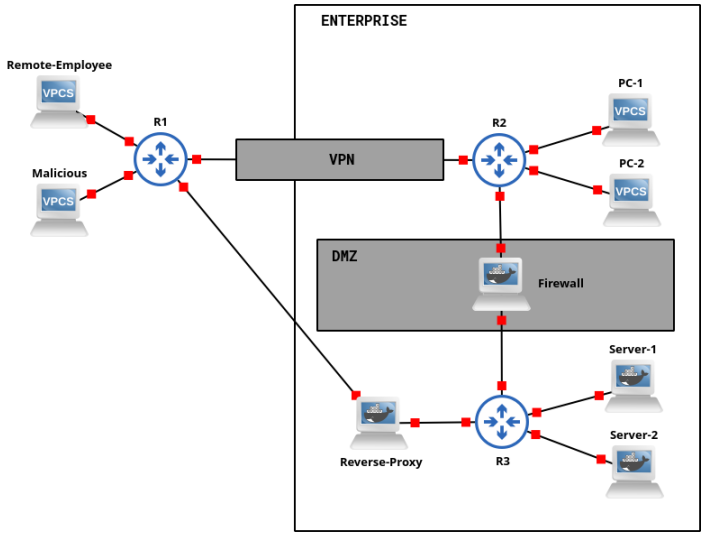

Figure 2: Basic topology of the project

3 Milestone 1

3.1 Initial Setup

3.1.1 Implementation

In this milestone, you will implement the topology depicted in Figure 3. As explained in the project description, the initial topology must contain:

- User & Malicious computers
- Office network PCs 1 & 2
- Servers 1 & 2
- Routers 1 & 2 & 3

The application servers are basic NGINX web servers. They are configured using Nginx. The web-server images are available following this link GNS3 Toolbox. More can be found in the following link Nginx web-server.

The **VPN** and **Firewall** will be configured later in the milestone.

3.1.2 Threat Model

Based on the topology elaborated in the previous step, perform a STRIDE analysis. From this analysis, consider 5 attacks and provide mitigations for

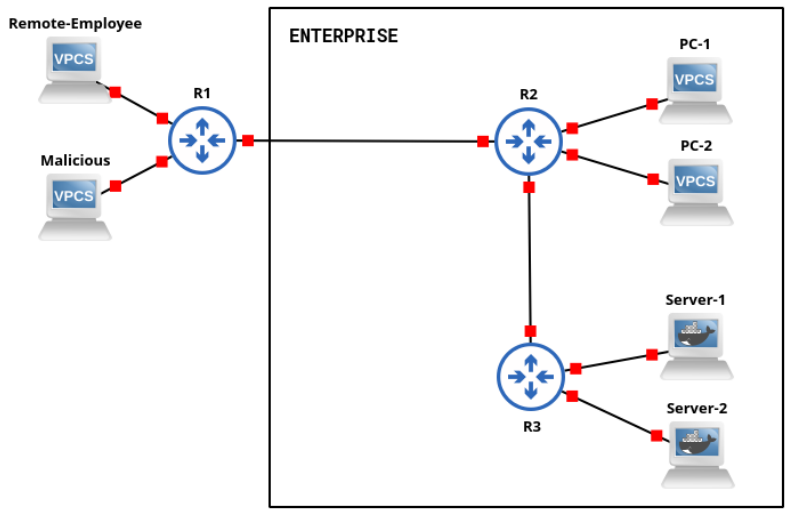

Figure 3: Milestone 1 - Initial Setup Topology

each of them. Then, evaluate the risk severity of these attacks with a likelihood-impact heat map.

3.2 Security Implementation

3.2.1 Virtual Private Network

The virtual private network will be used to allow communication between remote employees and enterprise devices. You will need a site-to-site VPN for this task, see Lab 2 background exercises. The malicious external PC should not have access to the enterprise's computers (VPN).

3.2.2 Firewall

The firewall is used to filter connections to the application server. To ensure a minimum level of security, it should define two rules; office computers from IT Department (illustrated with **PC-1**) should pass the firewall to access the servers, while office computers from Human Resources (illustrated with **PC-2**) must be filtered out.

- **PC-1** should be able to access **R3**
- **PC-2** and **connection from VPN** should be blocked by the Firewall
- **Application servers** should not be allowed to initiate connection to office network. This prevents compromised servers to access office network.

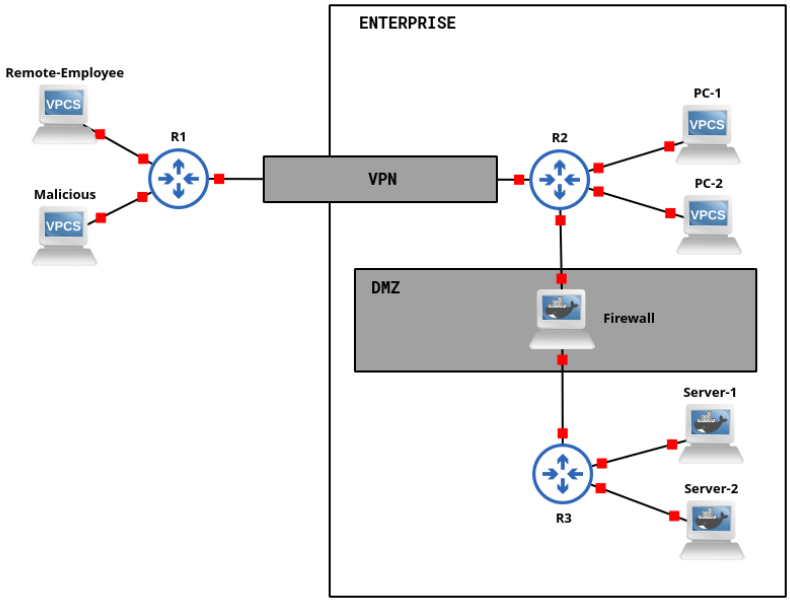

Figure 4: Milestone 1 - VPN & Firewall Topology

3.3 Summary

Assumptions

1. Routers should be configured with RIPv2, see Lab 1 background exercises.
2. The malicious external PC should not have access to the enterprise's computers (VPN).
3. For the VPN, it is recommended to add a router between R1 and R2 to serve as an entry point.

Deliverables

- **Initial Setup**
  1. Complete initial setup implementation and provide demonstration
  2. Thread model for the initial setup
- **Security Implementation**
  1. Firewall + VPN demonstration

4 Milestone 2

4.1 Reverse Proxy Implementation

To make the access to the web servers available through the Internet, you need to implement a reverse proxy. The reverse proxy should redirect packets from the Internet to the application servers, and vice versa. In this milestone, the first step consists of implementing the reverse proxy between routers R1 and R3.

The reverse proxy used here is made from a Debian instance. Few references to help you configure it:

- Images for the reverse proxy appliance are available following this link GNS3 Toolbox.
- NGINX Reverse Proxy
- A practical guide to implementing reverse proxy using dockerized nginx with multiple apps
- Module ngx_http_proxy_module

4.2 Web Application Firewall

Reverse proxies or web servers are frequently targeted by malicious users as attack surfaces on the company network. To address this issue, you need to harden the security of the reverse proxy. To secure your implementation, read the following document: Nginx Security Hardening: A Complete Guide for Production Environments. You are expected to implement some security features present in the document:

1. Hide Server Version Information
2. Configure Secure HTTP Headers
3. Implement SSL/TLS Best Practices
4. Control Request Methods and Size Limits
5. Implement Rate Limiting
6. Secure File and Directory Access
7. Configure Proper Logging and Monitoring
8. Implement Geographic and IP-based Restrictions

4.3 Summary

Assumptions The reverse proxy should actually only redirect packets from the Internet to the application servers, and vice versa.

Deliverables

- **Reverse Proxy Implementation**
  1. Complete reverse proxy implementation and provide demonstration
- **Web Application Firewall**
  1. Implement the security features and provide demonstration
  2. With the help of slides, provide explanation on why you need to implement those features

5 Milestone 3

In this last milestone, you will extend your existing network by implementing **one of the security features proposed below**.

You must **select one option** and implement it in your infrastructure. For the deliverables, you must clearly **justify your choice**.

This milestone is given to you **without detailed guidance**. You are expected to perform your own research and determine how to implement the selected feature.

5.1 Implementation

Choose **one** of the following options:

- **Department-based VLAN**: In many companies, VLANs are used to segment communication between departments. Explain how this segmentation improves security. Create at least two VLANs, called *'IT'* and *'HR'*. You must adapt your network accordingly (e.g. implement appropriate firewall rules, control inter-VLAN communication, ...).
- **Remote Firewall Access**: Companies often allow administrators to remotely access infrastructure for maintenance. Modify the firewall (DMZ) configuration to allow an IT manager to connect remotely through the VPN to access to internal servers for maintenance. However, the remote HR manager (through VPN) must NOT have access for maintenance but should still be able to reach some limited services. You will therefore need to add at least one additional remote employee (do not hesitate to rename remote PC appropriately) and add different services on the servers. Discuss how these policies enforce role-based access control and why is it interesting in general cases.

- **Credential-based Authentication**: Configure the reverse proxy to require authentication before accessing the website. You are asked to implement an authentication with password on the reverse proxy to access to websites.
- **Intrusion Detection System (IDS)** Reverse proxies generate detailed logs that can be used to detect suspicious behavior. Create a scenario including a normal user activity, and a suspicious or malicious activity. Analyze the logs and identify indicators of suspicious behavior. Explain how log monitoring can support Intrusion Detection System.
- **Network Intrusion Prevention System (NIPS)** Integrate Snort with your infrastructure to create a Network Intrusion Prevention System. Snort should analyze traffic before it reaches the reverse proxy and block potentially malicious packets. Demonstrate detection or prevention of at least one attack scenario.
- **Caching & Poisoning** Reverse proxies can cache frequently requested content to improve performance and reduce server load. Implement a basic caching reverse proxy and demonstrate how caching improves performance, and an example of cache poisoning. You should also describe possible mitigation techniques to such attack (implementation is optional but encouraged).

5.2 Summary

Deliverables

- Description of the chosen feature
  - Choice motivation and purpose
  - Assumptions and their justification
  - Security or resilience improvements and limitations
- Implemented architecture and configuration
- Justification of your design choices
- Scenario demonstration

As a reminder, you must not exceed **10 minutes for the whole presentation**.